

Politique de rétention et de disposition des données

— Horizon

Organisation : Vibe Coding Mind **Application** : Horizon (gestion de finances personnelles pour couples) **Responsable de la sécurité et de la protection des renseignements personnels** : Sébastien Normandeau — sebastiennormandeau@gmail.com **Version** : 1.1 — 22 juillet 2026 · **Prochaine revue** : juillet 2027 (revue annuelle obligatoire) *Journal* : 1.1 — passage de `horizon-dbbba0` en pilote restreint avec de vraies données bancaires (§4) ; ajout de la remise à zéro en libre-service et du départ d'un foyer à la section disposition (§3).

Cette politique précise, pour chaque catégorie de données traitée par Horizon, la durée de conservation, l'événement qui déclenche sa suppression et la méthode de disposition employée. Elle complète [SECURITY_POLICY.md §7](#) (cycle de vie des données) et [ACCESS_CONTROL_POLICY.md](#).

1. Principe directeur : minimisation

Horizon ne conserve que les données nécessaires au fonctionnement du service, aussi longtemps que le compte qui les a produites reste actif. Deux conséquences pratiques :

- **Aucune archive de comptes supprimés.** La suppression d'un compte efface les données correspondantes des systèmes de production ; rien n'est déplacé vers un stockage « au cas où ».
- **Aucun identifiant bancaire n'est jamais collecté.** L'authentification bancaire se fait chez Plaid ; Horizon ne détient que des jetons d'accès révocables (voir §2).

2. Catégories de données et durées de conservation

Catégorie	Emplacement	Durée de conservation	Déclencheur de suppression
Jetons d'accès Plaid	Firestore <code>bank_connections</code> (interdiction totale de lecture/écriture cliente)	Tant que la connexion bancaire est active	Suppression du compte → révocation chez Plaid (<code>/item/remove</code>) puis effacement du document
Transactions synchronisées	Firestore <code>transactions</code> (montant, nom du commerçant, date, catégorie)	Tant que le compte est actif	Suppression du compte (transactions de l'utilisateur) ; suppression du foyer (toutes) ; retrait signalé par Plaid via <code>/transactions/sync</code> (<code>removed</code>)
Profil utilisateur	Firestore <code>users/{uid}</code> (prénom affiché, rattachement au foyer, palier d'abonnement)	Tant que le compte est actif	Suppression du compte
Compte d'authentification	Firebase Identity Platform (courriel, mot de passe haché, second facteur TOTP)	Tant que le compte est actif	Suppression du compte (dernière étape de la séquence)

Catégorie	Emplacement	Durée de conservation	Déclencheur de suppression
Foyer, budgets et règlements	Firestore <code>households/{id}</code> + sous-collections <code>monthly_budgets</code> , <code>settlements</code>	Tant qu'au moins un membre est actif	Suppression du compte du dernier membre
Bilans et conseils du coach IA	Firestore <code>households/{id}/reports/{periodId}</code> (agrégats calculés + texte généré)	Tant que le foyer existe	Suppression du foyer (incluse dans l'effacement récursif)
Palier d'abonnement (RevenueCat)	Champ <code>subscription_tier</code> sur <code>users</code> et <code>households</code>	Tant que le compte / le foyer existe	Suppression du compte ou du foyer. <i>L'historique d'achat détenu par RevenueCat et par les boutiques (Apple, Google) relève de leurs propres politiques de conservation et n'est pas sous notre maîtrise.</i>
Compteurs anti-abus	Firestore <code>rate_limits</code> (interdiction totale d'accès client)	Fenêtre glissante par fonction (de 1 heure à 24 heures)	Purge automatique à chaque appel : les horodatages sortis de la fenêtre sont éliminés
Journaux d'exécution	Google Cloud Logging (Cloud Functions)	30 jours — valeur par défaut de la plateforme, non modifiée	Expiration automatique du seau de journaux
Rapports de plantage	Firebase Crashlytics	90 jours — valeur par défaut de la plateforme, non modifiée	Expiration automatique

Aucune donnée n'est transmise à l'API Claude d'Anthropic à des fins de conservation : le coach IA reçoit uniquement des agrégats anonymisés au moment de la demande, sans identifiant personnel ni transaction brute (détail dans [assets/legal/privacy.md](#) §3).

3. Méthode de disposition — suppression d'un compte

La suppression est offerte **en libre-service** dans l'application (Réglages → « Supprimer mon compte », avec confirmation forte). Elle est exécutée par la fonction serveur `deleteAccount` ([functions/src/account.ts](#)), limitée à 3 exécutions par jour et par utilisateur. La vérification du courriel n'est volontairement **pas** exigée : un utilisateur doit toujours pouvoir exercer son droit à l'effacement, même si son compte n'est pas confirmé.

Séquence réellement exécutée, dans cet ordre :

Étape 1 — Connexions bancaires. Les documents `bank_connections` dont le champ `user_id` correspond à l'utilisateur sont parcourus. Pour chacun, le jeton d'accès est d'abord révoqué auprès de Plaid par un appel `/item/remove`, puis le document Firestore est effacé. *Comportement en cas d'échec* : si l'appel à Plaid échoue (indisponibilité du service, jeton déjà révoqué), l'erreur est consignée dans les journaux et la suppression du

document se poursuit — le jeton disparaît de nos systèmes dans tous les cas. Les journaux sont surveillés pour détecter un item qui resterait actif chez Plaid et le révoquer manuellement.

Étape 2 — Transactions personnelles. Les documents de la collection `transactions` portant à la fois le foyer de l'utilisateur et son identifiant comme payeur (`paid_by_user_id`) sont supprimés par lots de 400 opérations (la limite Firestore étant de 500 écritures par lot).

Étape 3 — Foyer. Deux cas, selon qu'un partenaire subsiste :

- **L'utilisateur est le dernier membre** : les transactions restantes du foyer sont supprimées par lots, puis le document du foyer est effacé **récurivement**, ce qui emporte l'ensemble de ses sous-collections — budgets mensuels, règlements de dette et bilans (y compris les conseils générés par le coach IA).
- **Un partenaire reste** : le foyer est conservé, car il contient aussi les données de cette autre personne. La place de l'utilisateur est libérée — son identifiant et son prénom sont mis à `null` , sa cagnotte personnelle et la dette interne sont remises à zéro. Les transactions du partenaire, qui lui appartiennent, ne sont pas touchées ; celles de l'utilisateur supprimé l'ont déjà été à l'étape 2.

Étape 4 — Profil et identité. Le document `users/{uid}` est supprimé, puis le compte d'authentification lui-même (`deleteUser`), ce qui invalide toutes les sessions et supprime le second facteur enrôlé.

L'opération est **irréversible** et l'interface l'annonce explicitement avant confirmation.

Deux autres voies d'effacement en libre-service

Outre la suppression du compte, l'application offre deux effacements ciblés, tous deux exécutés côté serveur avec confirmation forte par saisie d'un mot-clé (Réglages → « Gérer mon foyer ») :

- **Départ d'un foyer** (`leaveHousehold` , en cas de séparation) : révocation des items Plaid de la personne qui part puis effacement de ses connexions, suppression de **ses** transactions, effacement des bilans du foyer — ce sont des agrégats qui mêlent les dépenses des deux membres —, annulation de la dette interne consignée dans `settlements` , et régénération du code d'invitation pour que l'ancien code ne rouvre pas le foyer. Le compte de la personne est conservé : elle peut créer un nouveau foyer.
- **Remise à zéro du foyer** (`resetHouseholdData`) : efface connexions bancaires, transactions, budgets, règlements et bilans, et remet les cagnottes et la dette à zéro. Les comptes, le foyer et le second facteur MFA sont conservés. Réservée au membre qui a créé le foyer lorsqu'ils sont deux, l'effacement portant aussi sur les données de l'autre.

Comme la suppression de compte, ces deux opérations effacent les documents des systèmes de production sans copie de sauvegarde applicative ; seules les sauvegardes d'infrastructure du §4 peuvent encore les contenir temporairement.

Portabilité préalable

Avant de supprimer son compte, l'utilisateur peut exporter l'intégralité de ses données au format JSON (Réglages → « Exporter mes données », fonction `exportMyData`) : profil, foyer, budgets mensuels, règlements et transactions. Le code d'invitation du foyer est délibérément exclu de l'export, n'étant pas une donnée personnelle.

4. Sauvegardes

Les sauvegardes sont le seul endroit où une donnée supprimée subsiste temporairement. Le dispositif prévu pour l'environnement de production (détail et commandes dans [PRODUCTION_CHECKLIST.md](#) §7) comporte deux niveaux :

Mécanisme	Fenêtre de rétention
Récupération à un instant passé (PITR)	7 jours
Sauvegardes planifiées quotidiennes	14 semaines

Conséquence assumée et documentée : une donnée effacée de la production peut demeurer dans les sauvegardes jusqu'à l'expiration de celles-ci, soit un maximum de 14 semaines, après quoi elle disparaît définitivement sans intervention. Les sauvegardes ne servent qu'au rétablissement du service après incident : elles ne sont ni consultées, ni exploitées, ni communiquées à des fins courantes, et leur accès est limité au responsable désigné ([ACCESS_CONTROL_POLICY.md](#) §2 A).

Une restauration effectuée après la suppression d'un compte pourrait réintroduire des données effacées : le cas échéant, la suppression est réexécutée sur les comptes concernés dans le cadre de la procédure de rétablissement.

État au 22 juillet 2026 : l'environnement `horizon-dbbao` est passé en **pilote restreint** et héberge de vraies données bancaires pour un nombre fermé de comptes nommés (accès production limité accordé par Plaid). Les deux mécanismes ci-dessus **y sont actifs** depuis cette date (`POINT_IN_TIME_RECOVERY_ENABLED` , rétention 7 jours ; sauvegardes quotidiennes planifiées, rétention 14 semaines), ainsi que la protection contre la suppression de la base. Ils devront être réactivés sur le projet de production le jour où il sera créé.

5. Fondement légal

Horizon est exploité depuis le Québec et se conforme à la **Loi 25** (loi modernisant des dispositions législatives en matière de protection des renseignements personnels), en particulier :

- **Minimisation** : seules les données nécessaires à la prestation du service sont collectées et conservées (§1).
- **Conservation limitée** : les renseignements ne sont pas conservés au-delà des fins pour lesquelles ils ont été recueillis — d'où l'alignement systématique de la rétention sur l'activité du compte (§2).
- **Droit à l'effacement** : l'utilisateur peut obtenir la suppression de ses renseignements ; Horizon l'offre en libre-service, sans avoir à en faire la demande ni à en justifier le motif (§3).
- **Droit d'accès et de portabilité** : export complet en libre-service (§3, *Portabilité préalable*).

Ces engagements sont communiqués aux utilisateurs dans la politique de confidentialité, [assets/legal/privacy.md](#) §4 (« Sécurité et Rétention »), également publiée à l'adresse <https://horizon-dbbao.web.app/privacy> — dont la version anglaise (`privacy_en.md`) est une traduction de courtoisie, la version française faisant foi.

Les demandes relatives aux renseignements personnels sont adressées au responsable désigné en tête du présent document, qui y répond dans un délai maximal de 30 jours.

6. Revue de la politique

Cette politique est revue **au moins une fois par année** par le responsable, ainsi qu'après tout changement de la structure des données, de la configuration des sauvegardes ou des obligations légales applicables. Chaque revue met à jour la version et la date en tête du document.